Legal and ethical basics: authorization, scope, Rules of Engagement and the cyber-crime law that applies in your country.

Legal and Ethical Basics of Cybersecurity

Cybersecurity professionals must follow legal and ethical principles while performing security testing, vulnerability assessments, penetration testing, and incident investigations.

Ethical hacking is the practice of identifying and testing security weaknesses in computer systems, networks, and applications with proper permission from the system owner.

The four important aspects of legal and ethical cybersecurity are Authorization, Scope, Rules of Engagement (RoE), and Cybercrime Laws.

1. Authorization

Authorization refers to obtaining official permission from the system owner or an authorized organization before performing any cybersecurity testing or security assessment.

It ensures that security testing is conducted legally and with the knowledge and consent of the responsible authority.

Importance of Authorization

i. Legal protection: Helps ensure that testing is performed within permitted legal boundaries.
ii. Prevention of unauthorized access: Prevents testers from accessing systems without permission.
iii. Clear responsibilities: Establishes who is permitted to conduct the assessment.
iv. Protection of sensitive information: Helps prevent unauthorized access to confidential data.
v. Professional accountability: Ensures that cybersecurity professionals follow ethical standards.

Example: A company hires a penetration tester to evaluate its website and provides written authorization before testing begins.

Important: Accessing or testing a system without permission may be illegal, even if the intention is to identify vulnerabilities.

2. Scope

Scope refers to the clearly defined boundaries, systems, applications, networks, and activities that are permitted during a cybersecurity assessment.

It specifies what can and cannot be tested.

Important Elements of Scope

i. Target systems: Defines the IP addresses, domains, servers, and applications included in testing.
ii. Testing boundaries: Identifies systems and resources that must not be tested.
iii. Permitted activities: Specifies which security testing techniques are allowed.
iv. Testing duration: Defines the approved testing period.
v. Restrictions: Identifies prohibited actions, such as accessing unrelated databases or modifying production data.

Example: A company permits penetration testing of its testing website at test.example.com but prohibits testing its production website and employee devices.

The tester must remain within the authorized scope.

3. Rules of Engagement (RoE)

Rules of Engagement (RoE) are a set of documented guidelines, conditions, and procedures that define how a cybersecurity assessment or penetration test must be conducted.

They establish the responsibilities of the security testers and the organization.

Important Components of Rules of Engagement

i. Authorization: Written approval from the responsible authority.
ii. Scope of testing: Identification of authorized targets and excluded systems.
iii. Testing methods: Techniques and tools that testers are allowed to use.
iv. Testing schedule: Dates and times when testing can take place.
v. Communication procedures: Contact details and methods for reporting issues.
vi. Data confidentiality: Procedures for protecting sensitive information discovered during testing.

vii. Incident handling: Actions to follow if testing causes a system failure or reveals a serious security issue.

viii. Reporting requirements: Instructions for documenting vulnerabilities, findings, and recommendations.

Example: During a penetration test, a company allows vulnerability scanning and controlled exploitation but prohibits denial-of-service attacks, data deletion, and unauthorized access to customer information.

Difference Between Authorization, Scope and RoE

Basis	Authorization	Scope	Rules of Engagement
Meaning	Official permission	Boundaries of testing	Guidelines for conducting testing
Purpose	Establishes permission to test	Defines what can be tested	Defines how testing must be performed
Main question	Are we allowed to test?	What are we allowed to test?	How and when should we test?
Example	Written approval	Specific IP addresses or websites	Approved tools, testing hours, and restrictions

4. Cybercrime Laws in India

In India, the primary legislation governing cybercrime is the Information Technology Act, 2000 (IT Act, 2000), as amended by the Information Technology (Amendment) Act, 2008 and subsequent legal changes.

The Act addresses computer-related offences, unauthorized access, identity theft, online fraud, privacy violations, and other cybercrimes.

Important Sections of the IT Act, 2000

Section	Description
Section 43	Provides for compensation relating to specified unauthorized computer activities and damage
Section 66	Punishment for computer-related offences committed dishonestly or fraudulently
Section 66C	Punishment for identity theft
Section 66D	Punishment for cheating by personation using computer resources
Section 66E	Punishment for violation of privacy
Section 66F	Punishment for cyber terrorism
Section 70	Protection of designated critical computer systems
Section 70B	Establishes the functions of CERT-In as the national cybersecurity incident-response agency

Role of CERT-In

The Indian Computer Emergency Response Team (CERT-In) is India's national agency responsible for specified cybersecurity incident-response functions.

Its responsibilities include:

i. Collecting and analyzing information about cyber incidents.
ii. Issuing cybersecurity alerts and advisories.
iii. Coordinating incident-response activities.
iv. Providing guidance on cybersecurity threats and vulnerabilities.
v. Supporting the prevention and handling of cybersecurity incidents.

Under CERT-In's 2022 directions, covered organizations must report specified cybersecurity incidents within 6 hours of noticing them or being informed about them.

5. Ethical Responsibilities of Cybersecurity Professionals

Cybersecurity professionals should follow these ethical principles:

i. Obtain permission: Never perform security testing without proper authorization.
ii. Respect privacy: Protect personal and confidential information.
iii. Follow the scope: Test only approved systems and applications.
iv. Avoid unnecessary damage: Do not disrupt services, delete data, or harm systems.
v. Maintain confidentiality: Do not disclose vulnerabilities or sensitive findings to unauthorized individuals.
vi. Responsible reporting: Report discovered security weaknesses through approved communication channels.

Conclusion

Legal and ethical principles are essential in cybersecurity. Authorization ensures that testing is permitted, scope defines the boundaries of testing, and Rules of Engagement establish how the assessment should be conducted. In India, the Information Technology Act, 2000 is the principal cybercrime legislation.

Cybersecurity professionals must always work with proper authorization, follow agreed testing boundaries, protect sensitive information, and comply with applicable laws.